

[doc. web n. 10102444]
Provision of December 12, 2024
Register of Provisions
n. 770 of December 12, 2024

THE GUARANTOR FOR THE PROTECTION OF PERSONAL DATA

IN the meeting held today, attended by
Prof. Pasquale Stazione, President, Prof.
Ginevra Cerrina Feroni, Vice President, Dr.
Agostino Ghiglia and Attorney Guido Scorza, Members, and
Dr. Claudio Filippi, Deputy Secretary General;

HAVING REGARD TO Regulation (EU) 2016/679 of the European Parliament
and of the Council, of April 27, 2016, on the protection of natural persons
with regard to the processing of personal data, as well as the free
movement of such data and repealing Directive
95/46/EC, "General Data Protection Regulation" (hereinafter "Regulation");

HAVING REGARD TO Legislative Decree No. 196 of June 30, 2003, containing the
"Code regarding the protection of personal data,"
which includes provisions for the adaptation
of the national legal system to Regulation (EU)
2016/679 of the European Parliament and of the Council, of
April 27, 2016, on the protection of natural persons
with regard to the processing of personal data, as well as the free
movement of such data and repealing Directive 95/46/EC (hereinafter
the "Code");

HAVING REGARD TO Legislative Decree No. 101 of August 10, 2018, containing
"Provisions for the adaptation of national legislation
to the provisions of Regulation (EU) 2016/679 of the European Parliament
and of the Council, of April 27, 2016, on the protection of
natural persons with regard to the processing of personal data, as well as the free
movement of such data and repealing Directive 95/46/EC";

HAVING REGARD TO Regulation No. 1/2019 concerning
internal procedures with external relevance,
aimed at carrying out the tasks and
exercising the powers assigned to the Guarantor for the
protection of personal data, approved by
resolution No. 98 of April 4, 2019, published in
G.U. No. 106 of May 8, 2019 and on www.gpdp.it, doc. web
n. 9107633 (hereinafter "Guarantor Regulation No.
1/2019");

HAVING REGARD TO the documentation on file;
HAVING REGARD TO the observations made by the Secretary
General pursuant to Article 15 of the Guarantor Regulation No.
1/2000 on the organization and functioning of the Office of the Guarantor for the
protection of personal data, doc. web n. 1098801;
Rapporteur Prof. Ginevra Cerrina
Feroni;

PREMISED

1. The violation of personal data
By note dated XX, subsequently supplemented by

communication dated XX, the Health Authority of Alto Adige, hereinafter "Authority," transmitted to the Authority, pursuant to Article 33 of the Regulation, a notification of a personal data breach, in which it was stated that "a contracted physician operating at the Authority's clinics, regarding the issue of 'reduction of service hours,' wrote to several internal and external subjects (info@ordinemedici.bz.it) attaching to his communication the list of patients seen on a specific day. The communication was sent in plain text and included the following data: name – surname – date of birth – residence of the patient as well as the location of service provision, service provided, indication on paying patient, exempt (with indication of the exemption code), tax code and mobile number." In the same communication, it was highlighted that "the author of the breach sent in a single email communication the attachment with the breached data to 15 Company Structures and various Subjects including the order of physicians of the Province" and that, as technical and organizational measures adopted (or proposed for adoption) to remedy the breach and reduce its negative effects for the interested parties and to prevent similar future breaches, the following were indicated: "Involvement of the DPO; Request to all structures and subjects that received the attachment to proceed with the relative deletion; Initiated disciplinary procedure; Initiated process for reporting the incident to the order of physicians"; "the Authority provided guidance on the correct method of sending so-called sensitive data – such guidance is available on the intranet page in the privacy section of the Authority itself." The same Authority attached the documentation containing the aforementioned email, from which it is inferred that the transmission of the list of patients (13) was carried out in order to provide clarifications regarding the hours worked ("hereby to emphasize that the hours written in the resolution regarding the Tuesday clinic in Laives are not the actual ones compared to the list of patients set by the CUP. See attached example").

2. The notification of breaches and the defensive submissions

Regarding the described case, the Office, based on what was represented by the data controller in the notification of the breach as well as subsequent evaluations, notified the Authority, with act No. XX of XX, pursuant to Article 166, paragraph 5, of the Code, of the initiation of a procedure for the adoption of the measures referred to in Article 58, paragraph 2, of the Regulation, inviting the aforementioned data controller to submit to the Guarantor defensive writings or documents or to request to be heard by the Authority (Article 166, paragraphs 6 and 7, of

the Code; as well as Article 18, paragraph 1, of Law No. 689 of November 24, 1981). In particular, the Authority deemed that the sending, by the healthcare professional operating at the Authority, to multiple subjects, including the Order of Physicians, of a of data protection and has implemented various measures to ensure compliance with the relevant regulations”;

- “the Company has established a dedicated team to oversee data protection compliance and to provide ongoing support and guidance to all employees”;
 - “the Company has also conducted a thorough review of its data handling procedures and has made necessary adjustments to prevent future occurrences of similar incidents”;
 - “the Company is committed to fostering a culture of data protection awareness among its employees and regularly updates its training materials to reflect the latest legal requirements and best practices”;
 - “the Company has engaged external experts to assist in enhancing its data protection framework and to conduct audits of its data processing activities”;
 - “the Company acknowledges the importance of transparency and has taken steps to improve communication with stakeholders regarding data protection matters”;
 - “the Company is continuously monitoring its data protection practices and is open to feedback from employees and external parties to further enhance its compliance efforts”;
 - “the Company is dedicated to ensuring that all personal data is processed in accordance with applicable laws and regulations, and takes any breaches seriously, implementing corrective actions as necessary”;
 - “the Company has established a reporting mechanism for employees to raise concerns or report potential data breaches, ensuring that all reports are taken seriously and investigated promptly”;
 - “the Company remains committed to protecting the privacy and rights of all individuals whose data it processes, and will continue to prioritize data protection in all its operations”.
- personal data protection addressed to employees and published on the company's intranet.”

3. The outcome of the investigative activity

Taking note of what was represented by the Company during the proceedings, it is observed that: for “personal data” it is understood as “any information relating to an identified or identifiable natural person (‘data subject’)” and for “data concerning health” as “data concerning the health status of the data subject that reveals information related to their past, present, or future physical or mental health. This includes information about the natural person collected during their registration to receive healthcare services or the related provision referred to in Directive 2011/24/EU of the European Parliament and of the Council; a number, symbol, or specific element assigned to a natural person to uniquely identify them for health purposes” (art. 4, par. 1, nos. 1 and 15 of the Regulation; Cons. no. 35);

the Court of Cassation has deemed that “the very act of communicating the need for healthcare treatment and, therefore, the existence of a ‘disease’ in a broad sense – understood as a situation that necessitates healthcare treatment – pertains to health data: it is not necessary, for this purpose, to specify what treatment or what disease is involved” (Sent. no. 28417/2023; see also, press release from the Court of Justice of the European Union no. 159/24, regarding the judgment of October 4, 2024, in case C-21/23);

for “communication” it is understood as “making personal data known to one or more specific subjects other than the data subject, the representative of the data controller in the territory of the European Union, the processor or their representative in the territory of the European Union, and the persons authorized, pursuant to art. 2-quaterdecies, to process personal data under the direct authority of the controller or the processor, in any form, including by making them available, consulting, or through

interconnection" (art. 2-ter, par. 4, lett. a) of the Code); information about health status may only be communicated to the data subject and may only be communicated to third parties based on an appropriate legal basis (art. 9 of the Regulation); the data controller is required to comply with the principles regarding data protection, including those of "minimization" and "integrity and confidentiality," according to which personal data must be "adequate, relevant, and limited to what is necessary in relation to the purposes for which they are processed" and "processed in a manner that ensures adequate security (...), including protection, through appropriate technical and organizational measures, against unauthorized or unlawful processing and against accidental loss, destruction, or damage" (art. 5, par. 1, lett. c) and f) of the Regulation). The adequacy of such measures must be assessed by the data controller in relation to the nature of the data, the object, the purposes of the processing, and the risk to the rights and freedoms of the data subjects, taking into account the risks arising from the destruction, loss, alteration, unauthorized disclosure, or access to personal data transmitted, stored, or otherwise processed (art. 32, par. 1 and 2 of the Regulation).

4. Conclusions: declaration of unlawfulness of the processing. Corrective measures pursuant to art. 58, par. 2, Regulation

In light of the above, it emerges that the conduct of the doctor was aimed, as stated by him, at providing clarifications regarding the working hours he performed. This purpose could have been achieved, in compliance with the aforementioned principle of minimization, without transmitting the documentation related to the patients, including information on the type and location of the service provided and on the exemption code.

Furthermore, in compliance with the principle of integrity and confidentiality of data and the obligation to adopt appropriate technical and organizational measures to ensure a level of security appropriate to the risk, considering the particular category of data processed, the Company should have provided specific instructions to healthcare operators who process health data of the Company's patients and draw attention to the regulations regarding personal data protection and the greater protection that health data deserve, which, by their nature, are particularly sensitive in terms of rights and fundamental freedoms, given that the context of their processing could create significant risks to the rights and fundamental freedoms.

In light of the evaluations mentioned above, taking into account the statements made by the data controller during the investigation and considering that, unless the act constitutes a more serious crime, anyone who falsely declares or certifies news or circumstances or produces false acts or documents in a proceeding before the Guarantor is liable under art. 168 of the Code "Falsehood in declarations to the Guarantor and interruption of the execution of the tasks or the exercise of the powers of the Guarantor," the elements provided by the data controller in the aforementioned defensive memorandum and during the hearing do not allow for overcoming the observations notified by the Office with the aforementioned initiation act of the proceedings, nor do any of the cases provided for in art. 11 of the Guarantor Regulation no. 1/2019 apply.

In light of the above, it is noted that the described conduct of the healthcare professional (sending to multiple subjects, including the Order of Physicians, an email containing attached data on the to euro 3.000,00 (tremila/00) entro 30 giorni dalla notificazione del presente provvedimento, con conseguente estinzione della sanzione amministrativa pecuniaria.

DISPONE

la pubblicazione della presente ordinanza ingiunzione sul sito Internet del Garante, ai sensi dell'art. 166, comma 7, del Codice e dell'art. 16, comma 1, del Regolamento del Garante n. 1/2019.

Così deciso in data [data della decisione].

Il Garante per la protezione dei dati personali

[Firma]

[Nome e cognome del Garante]

[Funzione del Garante]

[Indirizzo del Garante]

[Contatti del Garante]

at half of the penalty imposed within the term referred to in Article 10, paragraph 3, of Legislative Decree No. 150 of September 1, 2011, provided for the submission of the appeal as indicated below;

ORDERS

a) pursuant to Article 166, paragraph 7, of the Code and Article 16, paragraph 1, of the Regulation of the Guarantor No. 1/2019, the publication of the injunction order on the Guarantor's website;

b) pursuant to Article 154-bis, paragraph 3 of the Code and Article 37 of the Regulation of the Guarantor No. 1/2019, the publication of this provision on the website of the Authority;

c) pursuant to Article 17 of the Regulation of the Guarantor No. 1/2019, the annotation of the violations and the measures adopted in accordance with Article 58, paragraph 2 of the Regulation, in the internal register of the Authority provided for by Article 57, paragraph 1, letter u) of the Regulation.

Pursuant to Article 78 of the Regulation, Articles 152 of the Code, and Article 10 of Legislative Decree No. 150/2011, an appeal against this provision may be submitted to the ordinary judicial authority, under penalty of inadmissibility, within thirty days from the date of communication of the provision itself or within sixty days if the appellant resides abroad.

Rome, December 12, 2024

THE PRESIDENT

Stanzione

THE REPORTER

Cerrina Feroni

THE DEPUTY SECRETARY GENERAL

Filippi